



تقرير التدقيق الداخلي

DOCUMENT CLASSIFICATION	Internal / Restricted
DOCUMENT REF	ISMS-DOC-09-5
VERSION	1.0
DATED	12 September 2026
DOCUMENT AUTHOR	XBYTE
DOCUMENT OWNER	سارة الحربي – مديرة أمن المعلومات (CISO)

سجل المراجعات

الاصدار	التاريخ	اسم المراجع	الملخص
1.0	2026-09-12	XPYTE	إصدار الأول – تقرير التدقيق الداخلي لبنك الأفاق الرقمية

التوزيع

الاسم	المنصب
عبدالله المحيسن	مجلس الإدارة رئيس
نورة القحطاني	الرئيس التنفيذي
سارة الحربي	مديرة أمن المعلومات (CISO)
فهد العتيبي	مدير تقنية المعلومات (CIO)
أحمد الغامدي	مدير المراجعة الداخلية
ليلى الدوسري	مديرة الشؤون القانونية

الاعتماد

الاسم	المنصب	التوقع	التاريخ
أحمد الغامدي	مدير المراجعة الداخلية		2026-09-12
سارة الحربي	مديرة أمن المعلومات (CISO)		2026-09-12

المحتويات

البند	العنوان	الصفحة
1	الملخص الإداري	8
2	تفاصيل التدقيق	9
2.1	معايير التدقيق والوثائق المرجعية	9
2.2	أهداف التدقيق	9
2.3	نطاق التدقيق	9
2.4	حالة حالات عدم المطابقة المرفوعة في التقييم السابق	11
3	نتائج التدقيق	12
3.1	سياق المنظمة	12
3.2	القيادة	12
3.3	التخطيط	12
3.4	حالات عدم المطابقة والملاحظات المرفوعة	13
4	خطة الزيارة القادمة	15
4.1	اليوم الأول	15
4.2	اليوم الثاني	15

Management summary (الملخص الإداري)

غطى هذا التدقيق أقسام السياق والقيادة والتخطيط من الجزء الإداري لمعيار ISO/IEC 27001. بشكل عام، وُجد أن هناك مستوى جيد من الدعم لنظام إدارة أمن المعلومات (ISMS) وأن الإدارة العليا ملتزمة بشكل كافٍ بنجاحه.

يتم إجراء تقييمات شاملة للمخاطر وفقاً لعملية موثقة، وتم إنشاء خطة معالجة قوية لمعالجة تلك المخاطر التي تتجاوز المستوى المقبول. لكن معايير إجراء تقييمات المخاطر يمكن تحسين تعريفها.

النتيجة الرئيسية للتدقيق هي أن أهداف أمن المعلومات بحاجة إلى تحديد على مستويات مختلفة بحيث يمكن الحكم على نجاح نظام إدارة أمن المعلومات بشكل أفضل. يجب معالجة هذا المجال كمسألة عاجلة.

Audit details(تفاصيل التدقيق)

التاريخ	16-08-2026 إلى 2026-08-15
الموقع	المقر الرئيسي – الرياض
المدققون	عمار المصباحي (المدقق الرئيسي)
المشاركون في التدقيق	سارة الحربي (CISO) ، فهد العتيبي (CIO) ، أحمد الغامدي (المراجعة الداخلية)، ليلي الدوسري (الشؤون القانونية)، خالد الشمري (HR)
ملخص النطاق	البند 4، 5، 6 من معيار ISO/IEC 27001:2022

1.1 Audit criteria and reference documents (معايير التدقيق والوثائق المرجعية)

تم استخدام **ISO/IEC 27001** المعيار الدولي لأمن المعلومات، كأساس لمعايير التدقيق. تم استخدام مدونة الممارسة **ISO/IEC 27002** حيث كان هناك حاجة لتوضيح متطلبات المعيار.

تم إجراء التدقيق باللغة العربية

1.2 Audit objectives (أهداف التدقيق)

وفقاً لمتطلبات المعيار، فإن الأهداف الشاملة لهذا التدقيق الداخلي هي توفير معلومات حول ما إذا كان نظام إدارة أمن المعلومات (ISMS) في بنك الأفاق الرقمية:

الهدف

—

يتوافق مع

متطلبات بنك الأفاق الرقمية لنظام ISMS الخاص به

يتوافق مع

متطلبات معيار ISO/IEC 27001 الدولي

1.3 Scope of audit

تم تغطية الأقسام التالية من معيار ISO/IEC 27001 خلال هذا التدقيق:

Table 1: Scope of audit

القسم	مشمول
4. سياق المنظمة	Y
4.1 فهم المنظمة وسياقها	Y
4.2 فهم احتياجات وتوقعات الأطراف المعنية	Y
4.3 تحديد نطاق نظام إدارة أمن المعلومات	Y
4.4 نظام إدارة أمن المعلومات	Y
5. القيادة	Y
5.1 القيادة والالتزام	Y
5.2 السياسة	Y
5.3 الأدوار والمسؤوليات والصلاحيات التنظيمية	Y
6. التخطيط	Y
6.1 الإجراءات لمعالجة المخاطر والفرص	Y
6.2 أهداف أمن المعلومات والتخطيط لتحقيقها	Y
6.3 تخطيط التغييرات	Y
7. الدعم	—
8. التشغيل	—
9. تقييم الأداء	—
10. التحسين	—
الضوابط المرجعية للملحق أ	—

1.4 Status of nonconformities raised at last assessment (حالة حالات عدم)

(المطابقة المرفوعة في التقييم السابق)

عتباراً من تاريخ هذا التدقيق، كانت حالة حالات عدم المطابقة التي أثّرت في التقييم السابق كما يلي:

المرجع	الوصف	النوع	الإجراءات	الحالة
NCR-001	عدم تضمين أهداف أمن المعلومات في السياسة	Minor Nonconformity	تم تحديد الأهداف في SMS-DOC-G2 وثيقة	مغلق
NCR-002	عدم إجراء مراجعة دورية لصلاحيات الوصول	Minor Nonconformity	تم إجراء مراجعة شاملة للصلاحيات الموروثة	مغلق

Audit findings(نتائج التدقيق)

المصدر: القالب – الصفحات 13-16 + دراسة الحالة

الشرح للدكتور: النتائج التفصيلية لكل قسم.

1.5 Context of the organisation(سياق المنظمة)

القضايا الخارجية والداخلية التي تؤثر على نظام إدارة أمن المعلومات مفهومة جيداً، وتم النظر في احتياجات وتوقعات الأطراف المعنية. لأغراض الشهادة، يتم تعريف نطاق نظام إدارة أمن المعلومات في بنك الآفاق الرقمية على النحو التالي:

"إدارة أمن المعلومات في توفير الخدمات المصرفية والمالية التي يقدمها بنك الآفاق الرقمية لعملائه وفقاً لبيان قابلية التطبيق v1".

تم الاتفاق على أن هذا النطاق لا يزال صالحاً لأغراض التدقيق.

1.6 Leadership(القيادة)

سياسات أمن المعلومات موجودة في معظم المجالات، على الرغم من أن الأهداف لم يتم تحديدها في بعض الإدارات (تم رفع NCR-001). نظام إدارة أمن المعلومات متكامل بشكل جيد مع العمليات التجارية ويتم توفير موارد كافية.

التواصل من الإدارة العليا جيد، ولكن يمكن استخدام المزيد من اجتماعات الفريق (تم رفع OBS-001) لتوصيل رسالة الأمن. القيادة قوية بشكل عام والتحسين المستمر يُعزز بشدة داخل البنك.

تتضمن سياسة أمن المعلومات عالية المستوى العناصر المطلوبة ولكن ليس، كما ذكر سابقاً، إطار عمل لتحديد الأهداف. السياسة معتمدة ومُوصَّلة بشكل جيد. الأدوار والمسؤوليات مفهومة ومنقَّذة بوضوح. مديرة أمن المعلومات مسؤولة عن نظام إدارة أمن المعلومات والتقارير منه.

النتيجة: متوافق جزئياً (Partially Compliant) — مع حالات عدم مطابقة

1.7 Planning(التخطيط)

تم إجراء تقييم مخاطر مؤخراً باتتبع عملية موثقة، على الرغم من أن معايير إجراء التقييمات غير محددة بالكامل (تم رفع NCR-002). تم تقييم المخاطر بشكل شامل وتم تحديد مجموعة مناسبة من الضوابط لمعالجة المخاطر التي تتجاوز عتبة القبول.

خطة معالجة مخاطر قابلة للتطبيق موجودة ويتم مراقبتها كجزء من مراجعات الإدارة. تم إنتاج بيان قابلية التطبيق وتبدو الادراجات والاستثناءات معقولة. جميع المخاطر لديها مالكون محددون وقعوا على خطة معالجة المخاطر.

ومع ذلك، لم يتم تحديد أهداف أمن المعلومات في السابق، وبالتالي لم تكن هناك خطة لتحقيقها. تمت معالجة هذا المجال في ISMS-DOC-G2 (أهداف أمن المعلومات).

النتيجة: متوافق جزئياً (Partially Compliant)

1.8 Nonconformities and observations raised (حالات عدم المطابقة والملاحظات)

(المرفوعة)

حيث تم العثور على تعارض ضد المعيار، تم رفع أحد الأنواع الثلاثة من العناصر على النحو التالي:

التعريف	النوع
مشكلة كبيرة تمثل انهياراً في تشغيل نظام الإدارة	Major Nonconformity
خطأ واحد لا يشير في حد ذاته إلى انهيار نظام الإدارة	Minor Nonconformity
تعليق قد يكون مفيداً للمدقق، بناءً على خبرة تطبيقات ISMS أخرى	Observation

تم رفع حالات عدم المطابقة والملاحظات التالية نتيجة لهذا التدقيق:

1.8.1 NCR-001 – Major Nonconformity (عدم مطابقة كبيرة)

الحقل	القيمة
المرجع	NCR-001
النوع	عدم مطابقة كبيرة
المجال	السياسة والأهداف
البند	5.2 السياسة / 6.2 أهداف أمن المعلومات
الوصف	سياسة أمن المعلومات لا تتضمن أهدافاً أو إطار عمل لتحديدها. لم يتم تحديد أهداف في بعض الإدارات.
المتطلبات	يجب على الإدارة العليا إنشاء سياسة أمن معلومات تتضمن أهداف أمن المعلومات أو توفر إطاراً لتحديد أهداف أمن المعلومات.
الأدلة	السياسة لا تتضمن الأقسام المطلوبة ولم يتم إثبات أي أهداف.

ملاحظة: تمت معالجة هذه الحالة في REQUIRED-G2 - ISMS Objectives.docx.

1.8.2 NCR-002 – Minor Nonconformity (عدم مطابقة بسيطة)

الحقل	القيمة
المرجع	NCR-002
النوع	Minor Nonconformity
المجال	Information security risk assessment
البند	6.1.2
الوصف	معايير إجراء تقييمات مخاطر أمن المعلومات غير محددة بالكامل.
المتطلبات	يجب على المنظمة تحديد وتطبيق عملية تقييم مخاطر أمن المعلومات التي تحدد معايير مخاطر أمن المعلومات.
الأدلة	عملية تقييم ومعالجة المخاطر لا تغطي هذا المجال.

ملاحظة: تمت معالجة هذه الحالة في REQUIRED-ISMS-DOC-06-2 Risk Assessment Report.docx (القسم 2.3).

1.8.3 OBS-001 – Observation (ملاحظة)

الحقل	القيمة
المرجع	OBS-001
النوع	Observation
المجال	Leadership and commitment
البند	5.1
الوصف	يمكن للإدارة العليا استخدام المزيد من اجتماعات الفريق للتأكيد على أهمية نظام إدارة أمن المعلومات.
المتطلبات	يجب على الإدارة العليا إظهار القيادة والالتزام فيما يتعلق بنظام إدارة أمن المعلومات من خلال التواصل.
الأدلة	أظهرت محاضر اجتماعات الفريق أن الإدارة العليا لم تحضر أي منها خلال الأشهر الستة الماضية.

1.8.1 OBS-002 – Observation (ملاحظة)

الحقل	القيمة
المرجع	OBS-002
النوع	Observation
المجال	Information Security Awareness
البند	7.3
الوصف	نتائج محاكاة التصيد تُظهر أن 25% من الموظفين نقروا على الرابط، و12% أدخلوا بياناتهم.
المتطلبات	يجب على المنظمة التأكد من أن الأشخاص على دراية بسياسة أمن المعلومات.
الأدلة	تقرير محاكاة التصيد (القسم 4.7).

1.8.1 OBS-003 – Observation(ملاحظة)

الحقل	القيمة
المرجع	OBS-003
النوع	Observation
المجال	Access Control
البند	5.15, 8.2
الوصف	صلاحيات وصول موروثه من مشروع سابق لم تُلغ بعد (حادثة القسم 4.5).
المتطلبات	يجب توفير ومراجعة وتعديل وإزالة حقوق الوصول.
الأدلة	تقرير المراجعة الدورية لصلاحيات الوصول (القسم 4.5).
	📌 مصدر التعديل: دراسة الحالة – القسم 4.5

.Next Visit Plan (خطة الزيارة القادمة)

سيتم إجراء التدقيق التالي على مدار يومين، بدءاً من **15-03-2027**.

الجدول المقترح للتدقيق:

1.9 Day One (اليوم الأول)

TIME	AUDITOR	AUDITEE	AREAS TO BE COVERED
09:00	عمار المصباحي	سارة الحربي	Opening meeting
10:00	عمار المصباحي	فهد العتيبي	Clause 7: Support
11:00	عمار المصباحي	خالد الشمري	Clause 7.2: Competence
12:00	عمار المصباحي	سارة الحربي	Clause 7.5: Documented information
13:00	—	—	Lunch
14:00	عمار المصباحي	فهد العتيبي	Clause 8: Operation
15:00	عمار المصباحي	مدير SOC	Clause 8.2: Risk assessment
16:00	عمار المصباحي	مدير التطوير	Clause 8.3: Risk treatment
17:00	—	—	Day wrap-up and summary

1.104.2 Day Two (اليوم الثاني)

TIME	AUDITOR	AUDITEE	AREAS TO BE COVERED
09:00	عمار المصباحي	سارة الحربي	Initial briefing
10:00	عمار المصباحي	سارة الحربي	Clause 9: Performance evaluation
11:00	عمار المصباحي	أحمد الغامدي	Clause 9.2: Internal audit
12:00	عمار المصباحي	سارة الحربي	Clause 9.3: Management review
13:00	—	—	Lunch
14:00	عمار المصباحي	سارة الحربي	Clause 10: Improvement
15:00	عمار المصباحي	سارة الحربي	Annex A Controls
16:00	عمار المصباحي	—	Audit wrap-up and summary